

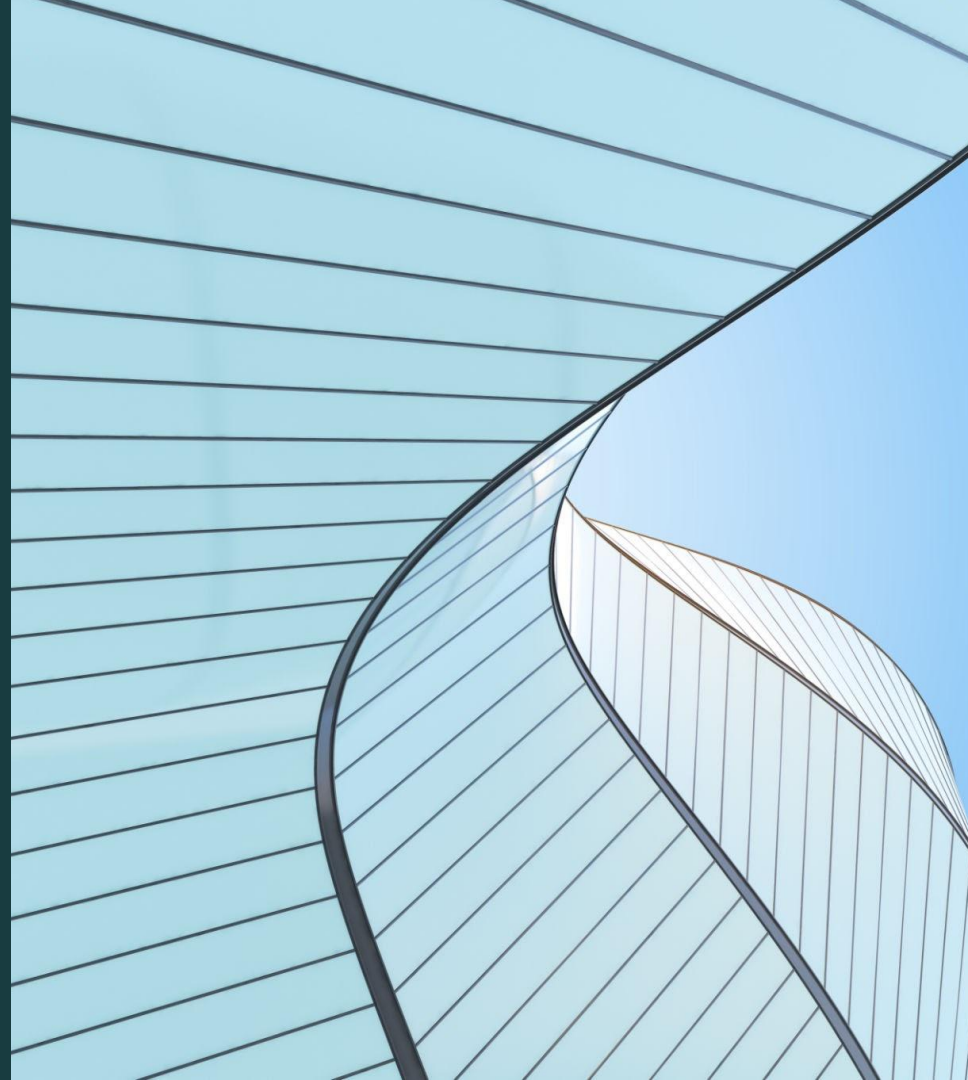
EMPRESA PYME

Plan Director de Seguridad

Horizonte: 24 meses

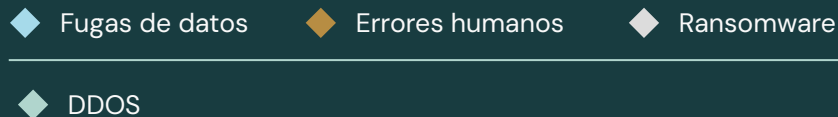
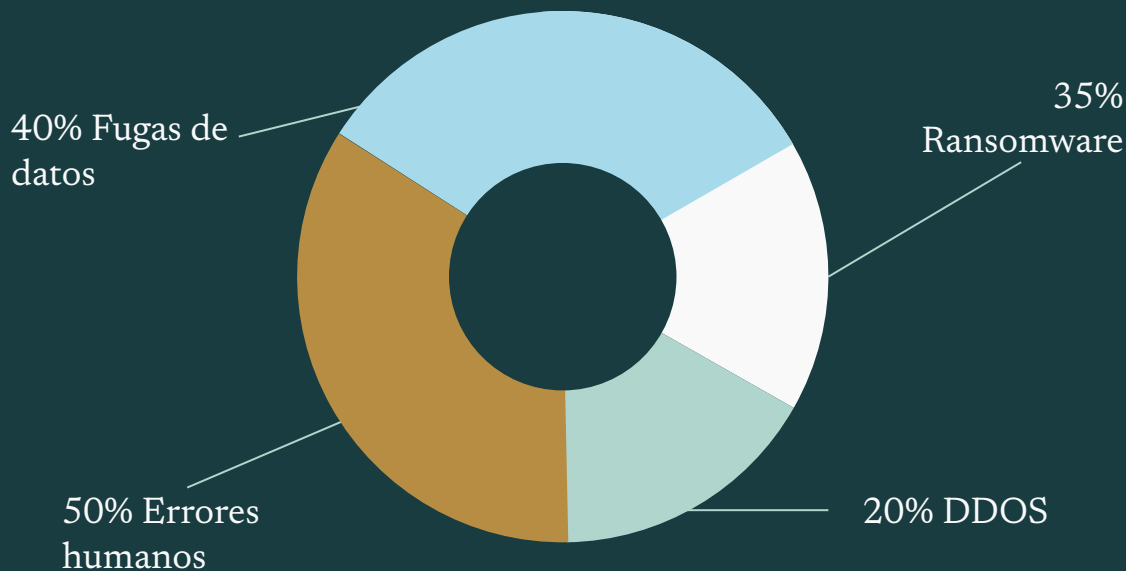
El objetivo es claro: pasar de una seguridad reactiva a una seguridad estratégica, alineada con su negocio digital, con un roadmap de 24 meses que reduzca el riesgo real, mejore la continuidad de servicio y refuerce la confianza de sus clientes.

¿Qué nivel de certeza quieren tener de que un incidente grave no va a parar su actividad ni dañar su reputación?"



Por qué estamos aquí

Ataques a PYMES



Contexto actual

2

- Amenazas crecientes
- Dependencia del canal online
- Responsabilidad legal y reputacional
- Necesidad de enfoque “risk-based”

Su organización ya está en el punto de mira: gestionan datos de autónomos y pymes, operan en dos sedes, dependen de la web y la tienda online para captar y servir a sus clientes.

Las amenazas actuales especialmente ransomware, ataques de denegación de servicio e ingeniería social no son escenarios hipotéticos, son el día a día en su sector

Si mañana su web queda caída 48 horas o sus datos quedan cifrados, ¿cuál es el impacto económico y reputacional aceptable para ustedes? Este PDS está construido precisamente para que esa pregunta tenga una respuesta controlada.

¿Qué es este Plan Director?

- Marco estratégico de seguridad
- Alineado con objetivos de negocio
- Basado en análisis de riesgo
- Referencias: ISO 27001 / ISO 27002 / RGPD

El Plan Director de Seguridad no es un documento teórico.

Es su hoja de ruta: prioriza qué proteger primero, con qué controles, en qué plazos y con qué responsables.

Lo hemos alineado con buenas prácticas y marcos reconocidos como ISO 27001/27002 y obligaciones legales como el RGPD, adaptado a su realidad, sin sobredimensionar.

La idea es muy simple: cada euro invertido en seguridad tiene un objetivo medible en reducción de riesgo y continuidad del negocio.

Si algo no aporta valor directo, no lo proponemos.



Situación actual

Hemos partido de su realidad: organización distribuida en dos sedes, fuerte orientación digital, múltiples departamentos que manejan información sensible de clientes y proveedores.

Su ventaja competitiva es la agilidad y la confianza. Eso implica que cualquier brecha, cualquier parada del canal online, cualquier filtración, impacta directamente en esa confianza.

**Asesoría a
autónomos y
pymes**

**150 empleados
2 sedes**

**Alta dependencia
web**

Tienda online

**Servicios TIC
RRHH
Legal
Comunicación**

¿Consideran hoy que sus medidas, tal y como están, reflejan el peso real que tiene lo digital en su negocio? Este PDS corrige precisamente ese desajuste.

Alcance (Scope) del plan

Incluye



Hemos definido un alcance muy claro y eficiente: nos centramos en los activos que si fallan, paran su negocio o exponen datos sensibles. No dispersamos esfuerzos en elementos de bajo impacto

Esto incluye estaciones de trabajo, móviles, servidores, redes, servicios en la nube y especialmente la web y tienda online gestionadas por terceros, donde proponemos reforzar contratos y controles.

Risk-Based

Este enfoque 'risk-based' garantiza que cada acción del PDS tiene impacto directo en continuidad y protección de datos.

Modelo de Gobierno Propuesto

6

01

Dirección General

02

Responsable
Seguridad / CISO

03

Responsable TIC

04

Responsable Legal /
RGPD

05

Comité de Seguridad
Mensual

Un plan sin gobierno se queda en papel.

Proponemos una estructura clara:

Dirección como sponsor, un Responsable de Seguridad que coordina, TIC para la parte técnica, Legal para cumplimiento y un Comité de Seguridad que se reúne de forma periódica para tomar decisiones.

El mensaje es sencillo: la seguridad deja de ser 'cosa de informática' y pasa a ser una decisión de negocio.

¿Quién debe estar sentado en ese comité por parte de ustedes?

Hallazgos clave del análisis de riesgo

7

Hemos analizado activos, amenazas y vulnerabilidades.

Datos
personales

Ransomware,
DoS, ingeniería
social

Dependencia
de proveedores
externos

Copias,
actualizaciones
y políticas:
madurez
limitada

El resultado: sus puntos más críticos son los datos personales, los servidores internos, la red corporativa y la web/tienda online. Detectamos ausencia de políticas formales, falta de control centralizado de actualizaciones, copias de seguridad con riesgos y poca visibilidad sobre la seguridad de proveedores externos.

El modelo de madurez lo hemos ajustado al nivel actual del departamento TIC: hay controles presentes pero de forma reactiva, sin estandarización ni reporting. El objetivo es pasar de un nivel inicial a un nivel gestionado y medido en 24 meses aplicando el ciclo de mejora continua. (planificar, implantar, medir y revisar)

¿Les sorprende este nivel de exposición o encaja con su percepción interna?

Riesgos prioritarios a tratar

Contexto

Hemos priorizado los riesgos que realmente pueden 'hacer daño'

El PDS que les presentamos está diseñado específicamente para reducir estos riesgos a niveles aceptables, documentados y medibles.

¿Su empresa puede permitirse alguno de estos riesgos?



Objetivos estrategicos

Traducimos el análisis en **objetivos concretos**: proteger la información sensible, asegurar que su canal digital ‘no cae’, cumplir con las obligaciones legales y crear una cultura mínima de seguridad en la organización.

Concepto clave: nivel de riesgo aceptable definido por Dirección (**con nuestra ayuda**). Es decir, ustedes deciden hasta dónde asumir riesgo y el PDS se diseña para mantenernos dentro de ese umbral, con datos y no con sensaciones.

Proteger datos de clientes y proveedores

Establecer cultura de seguridad

Garantizar continuidad del negocio

Reducir riesgo a nivel aceptable
definido por Dirección

Cumplir normativa RGPD

Líneas estratégicas de actuación

Gobierno & Políticas

Política de seguridad, roles claros y Comité activo.

Hardening tecnológico & copias

Refuerzo técnico, gestión de parches, copias cifradas y probadas.

Personas & formación

Formación específica contra phishing e ingeniería social.

Terceros & contratos de seguridad

Exigir y verificar garantías a proveedores de web, nube, etc.

Respuesta a incidentes & monitorización

Procedimientos claros, tiempos objetivo de recuperación y reporting

Construimos un programa coherente

Proyectos propuestos

11

Aterrizamos en proyectos concretos, cada proyecto viene con alcance, responsables y plazo para que ustedes vean exactamente qué están comprando en términos de seguridad.

Proyecto	Esfuerzo	Prioridad	Responsable
Política de Seguridad y Normativa Interna	Medio	Alta	R. Seguridad
Backup cifrado 3-2-1 + pruebas periódicas	Medio	Alta	Dep. Tic
Gestión centralizada de parches	Medio	Alta	Dep. Tic
Reforzar seguridad web/tienda con proveedor	Alto	Media	R. Seguridad
Programa anual de formación anti phishing	Bajo	Bajo	RRHH y Seguridad
Plan de respuesta ante Incidentes (IR Plan)	Medio	Alta	R. Seguridad

Prioridad y Roadmap

Quick wins críticos

Backups,
políticas mínimas,
control de parches,
revisar la web y
servicios cloud, y
definir el plan de
respuesta a incidentes.

0-6 meses

Consolidación controles clave

Consolidamos
controles,
revisamos
contratos con
terceros y
reforzamos la
monitorización

6-12 meses

Optimización y mejora continua

Pasamos a
optimización,
métricas,
auditorías
internas y
mejora continua

12-24 meses

Beneficios clave

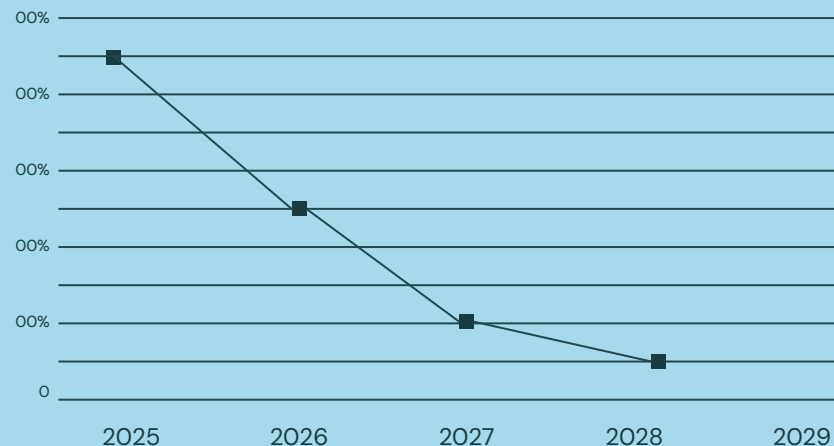
Reducen la probabilidad y el impacto de incidentes graves, tienen argumentos sólidos ante clientes, auditores y autoridades, y disponen de indicadores claros para saber si la inversión en seguridad está funcionando.

Es pasar de 'creo que estamos bien' a 'sé en qué punto estamos y qué estamos cubriendo'. Eso da tranquilidad de gestión y posiciona a su empresa como proveedor fiable en su sector."

¿Qué ganan con este Plan Director de Seguridad?

1. Reducción de riesgos críticos
2. Menos probabilidad de parada total
3. Evidencias de cumplimiento (RGPD, buenas prácticas)
4. Refuerzo reputacional frente a clientes
5. Decisiones basadas en métricas

Nivel de riesgo

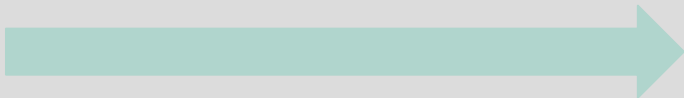


Seguimiento del PDS

El PDS incluye cómo se mide y se gestiona, no sólo qué hacer. Proponemos un cuadro de mando sencillo para Dirección con 4-5 KPIs clave: actualización de sistemas, fiabilidad de copias, incidentes críticos y tiempos de respuesta.

Además, una revisión semestral del plan permite adaptarlo a cambios de negocio o nuevas amenazas.

Así mantenemos el plan vivo y ustedes mantienen el control estratégico sin entrar al detalle técnico del día a día.



- **Comité de seguridad mensual**
- **Indicadores:**
 - % sistemas parcheados**
 - % copias verificadas**
 - Nº incidentes críticos**
 - Tiempos de respuesta (MTTR)**
- **Revisión semestral del roadmap**

Siguientes pasos

1. Validar alcance y riesgos prioritarios
2. Aprobar PDS y presupuesto asociado
3. Constituir Comité de Seguridad
4. Lanzar quick wins (0-6 meses)

Primero, validar hoy si el alcance y los riesgos prioritarios reflejan su realidad.

Segundo, aprobar el Plan Director de Seguridad con el presupuesto asociado y el compromiso de Dirección.

Tercero, constituir el Comité de Seguridad.

Cuarto, activar de inmediato los quick wins que reducen más riesgo en menos tiempo.

Dentro de 12 meses, cuando un cliente importante pregunte ‘¿cómo protegen mis datos?’, ¿Qué respuesta quieren poder darle? Este PDS está diseñado para que esa respuesta sea sólida y demostrable.